Università degli Studi di Padova

Dipartimento di Ingegneria dell'Informazione



Digital Forensics and Biometrics

A.A. 2026/2027

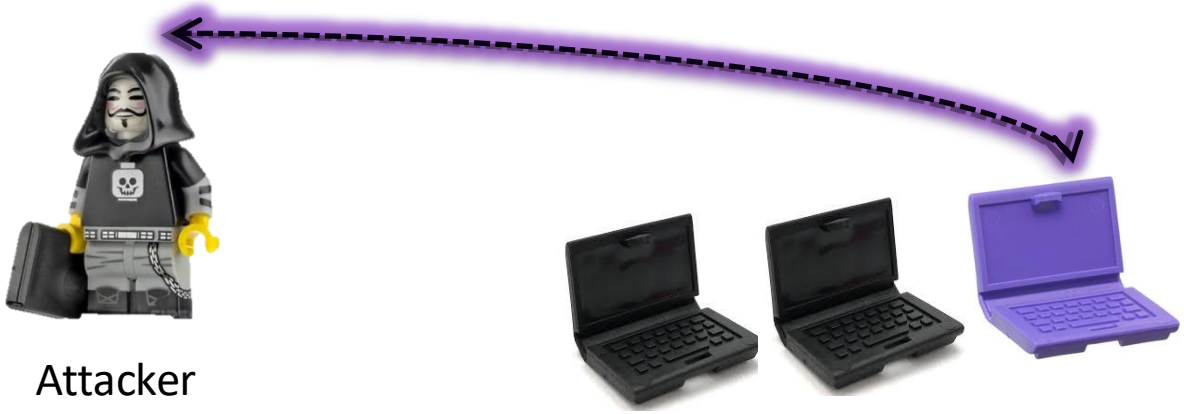
Lecture 02 : DE acquisition

Simone Milani
Room 216
DEI A

Phone: 049 827 7641
E-mail:
simone.milani@dei.unipd.it

ACQUIRING A DIGITAL EVIDENCE

PEOPLE AROUND DE



Attacker

Digital
Evidences

Suppose a computer is hacked and evidences are compromised files stored on HD.

INCIDENT RESPONSE SPECIALIST (IRS)

Incident Response Specialist



Digital
Evidences

Data breache is discovered: authorities are alerted about the fact!

Evidences could not be preserved: attention!

DIGITAL EVIDENCE FIRST RESPONDER (DEFR)



An appointed specialist intervenes on the scene to acquire the digital evidence: he can isolate the device, seize it or eventually acquire some files.

He can interact with IRS to get more information

DIGITAL EVIDENCE SPECIALIST AND FORENSIC LAB MANAGER

Evidence is brought to the lab for analysis

Forensic specialist comes into play

Conclusions can be drawn.



Digital Evidences

Digital Evidence First Responder



Digital Evidence Specialist



Forensic Lab Manager



ISO IEC 27037/2012: WHO? (1/2)

DEFR: digital evidence first responder

- Authorized operator that accesses information devices and systems for the first time
- Must be experienced
- May use collaborators



What does he have to do?

- Check and seizure the area containing digital devices
- Identify the person in charge for that area
- Keep people away from device and power supply
- Profile all the persons authorized to access the area
- Avoid changing the state of devices
- Document the scene, components, cables (pictures, video, drawings, schemes)
- Identify notes, diaries, post-it, manuals (look for passwork and PINs)

ISO IEC 27037/2012: WHO? (2/2)



DES: digital evidence specialist

Operator that is expert in digital evidences ≠ DEFR

DEFR is authorized, prepared and qualified to operate first on the crime scene to acquire and store digital evidences

DES can operate as a DEFR but has the competences to deal with a wide range of different technical issues (e.g., OS, network acquisitions, etc.)



IRS: incident response specialist

Operates first after the fact (it can not be someone in charge of the investigation, e.g., network manager after an attack)

Limits damages, interact with DEFR and other actors (legals), record actions

FLM: Forensics Laboratory Managers

Operates inside the forensics analysis lab



DIGITAL EVIDENCE ACQUISITION PHASES

HANDLING PROCESS FOR A DE

4 phases:

Identification: search, recognition and documentation of the possible evidence

Seizure: acquisition of the physical device containing possible DE

Acquisition: creation of a copy of the data

Preservation: storage and conservation of the integrity and original condition of the potential DE

Storage space:

- Safe environment where DE are kept
- Storage devices must not be exposed to magnetic fields, dust, vibrations or other agents (e.g., humidity, temperature) which could compromise the potential DE

IDENTIFICATION

IDENTIFICATION: BRIEFING!

What happened?

What looking for?

What do you expect to find? What not?

Privacy

Integrity (define tools and method to preserve it)



IDENTIFICATION: VOLATILE DATA

A digital evidence has a **physical and logical** consistency

Look for the devices that has some relevant data

Which priorities:

- Devices which presents **volatile data**
- Device **difficult to localize**
  - because of geography (e.g., cloud computing, SAN)
  - because of size (e.g., miniSD)



***Volatile data**: data stored in temporary memory—like RAM—that is lost when the system loses power or is restarted (e.g., active processes, open network connections, and current system state)*

A digital device (which receives, processes and stores data) can be

- connected to a network
- can have peripherals

N.B. If it has a network interface, we must identify which terminals had exchanged data/communications with it (regardless of the fact that it is connected or not at the intervetion time)

ODV: ORDER OF VOLATILITY

1. CPU Registers, Cache, and Real-time State

CPU registers, L1/L2/L3 cache memory
Current instruction pointer
Real-time clock/timers

2. RAM (Main Memory)

Running processes and active threads
Application data in memory
Clipboard contents
Loaded kernel modules/drivers
Open files and file handles
Encryption keys stored in RAM

3. Temporary Memory in Network Devices

Routing table entries
ARP cache
DNS cache
Active TCP/UDP sessions

4. Memory in Peripheral Devices

GPU VRAM contents
Printer buffer memory
Volatile storage in external devices

5. Disk-based Volatile Data

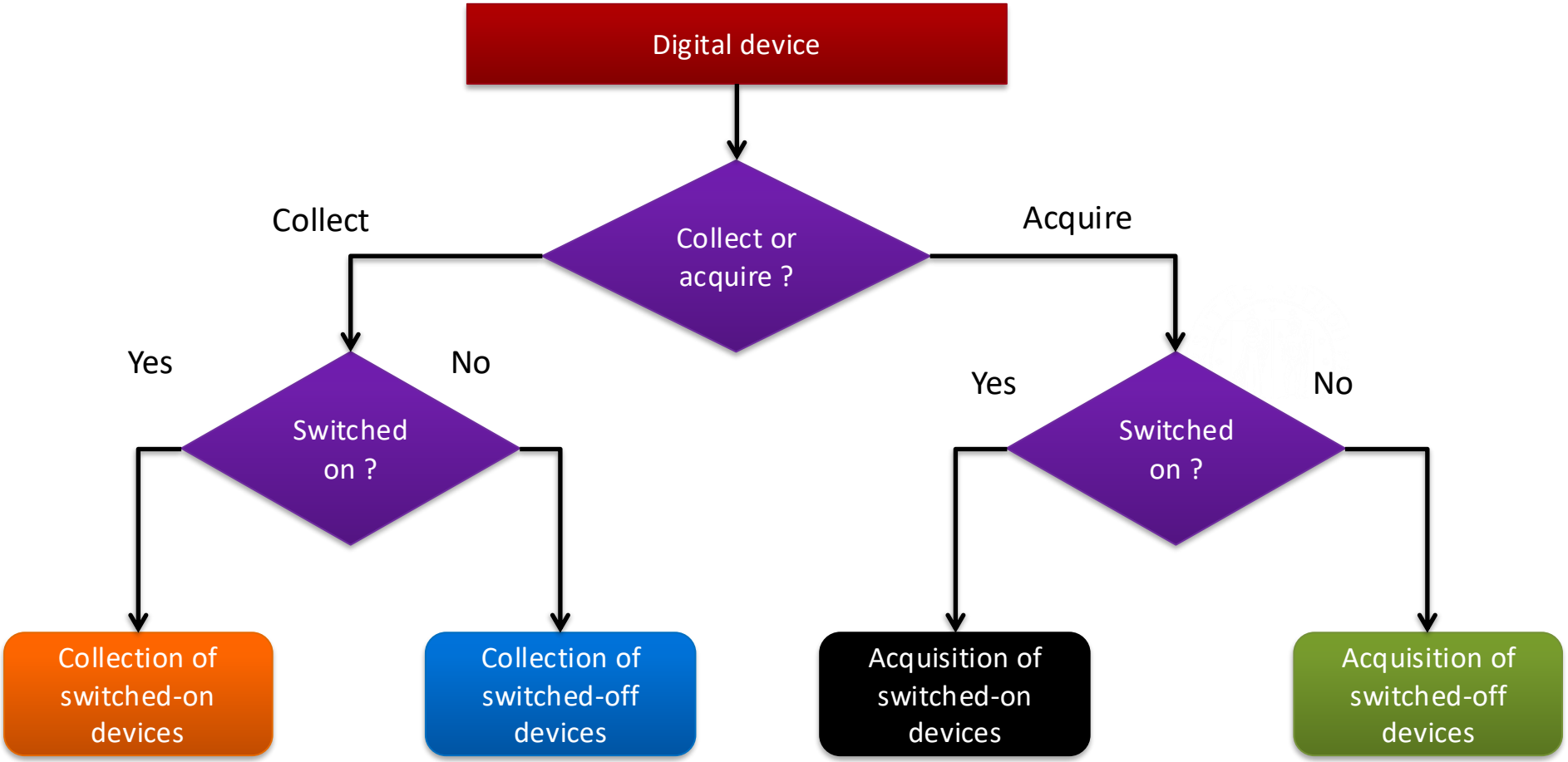
Pagefile/swap file (partially volatile)
Temporary files not yet written to permanent storage

6. Remote and Cloud-based Volatile Data

Data in remote system memory (e.g., chat messages in active sessions)
Real-time network logs from connected devices



IDENTIFICATION: SCHEME



IDENTIFICATION: DEFR'S OPERATIONS

DEFR must:

- Document type, brand, s/n for each storage device
- Identify all the computers and peripherals, together with their state
  If switched on, document what it is displayed (pictures, videos, description)
- Collect power cables for each device using batteries
- Use a wireless signal detector to identify eventual systems that are present but not immediately visible
- Take into consideration possible non-digital evidences (e.g., referred by people)

Pay attention to

- ⚠ Volatility
- ⚠ Use of cryptosystem on devices or on partitions
- ⚠ Critical elements of the systems
- ⚠ Legal requirements
- ⚠ Resources (availability of storage, time and personnel to acquire data)



COLLECTION OR SEIZURE

COLLECTION

Devices are seized and brought to the lab (n.b. taking the device can be dangerous)

Devices can be switched on or off

- DEFR must use the best practices based on costs and times (to be documented)
- Accessories must be gathered as well



Collection ≠ acquisition

Collection: physically removes the device from its location

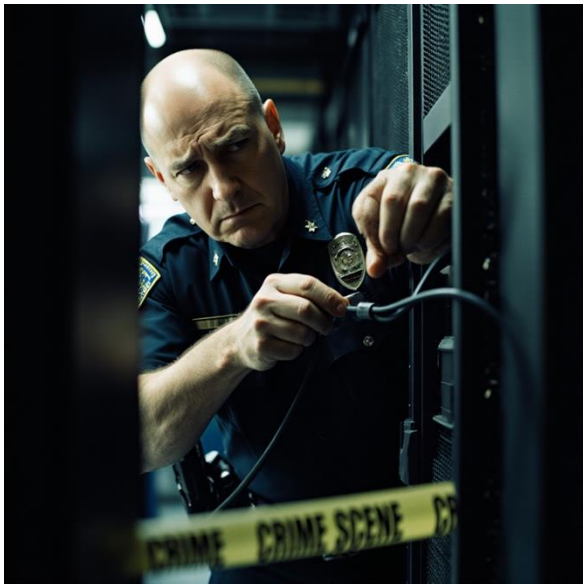
Acquisition: logical extraction of information from the device (e.g., extract files, info, metadata)

COLLECTION: CRITICAL SITUATIONS

There are devices that can not be switched off

Data centers providing services to other clients, video-surveillance systems, medical systems, critical control systems, etc.

Special attentions are required

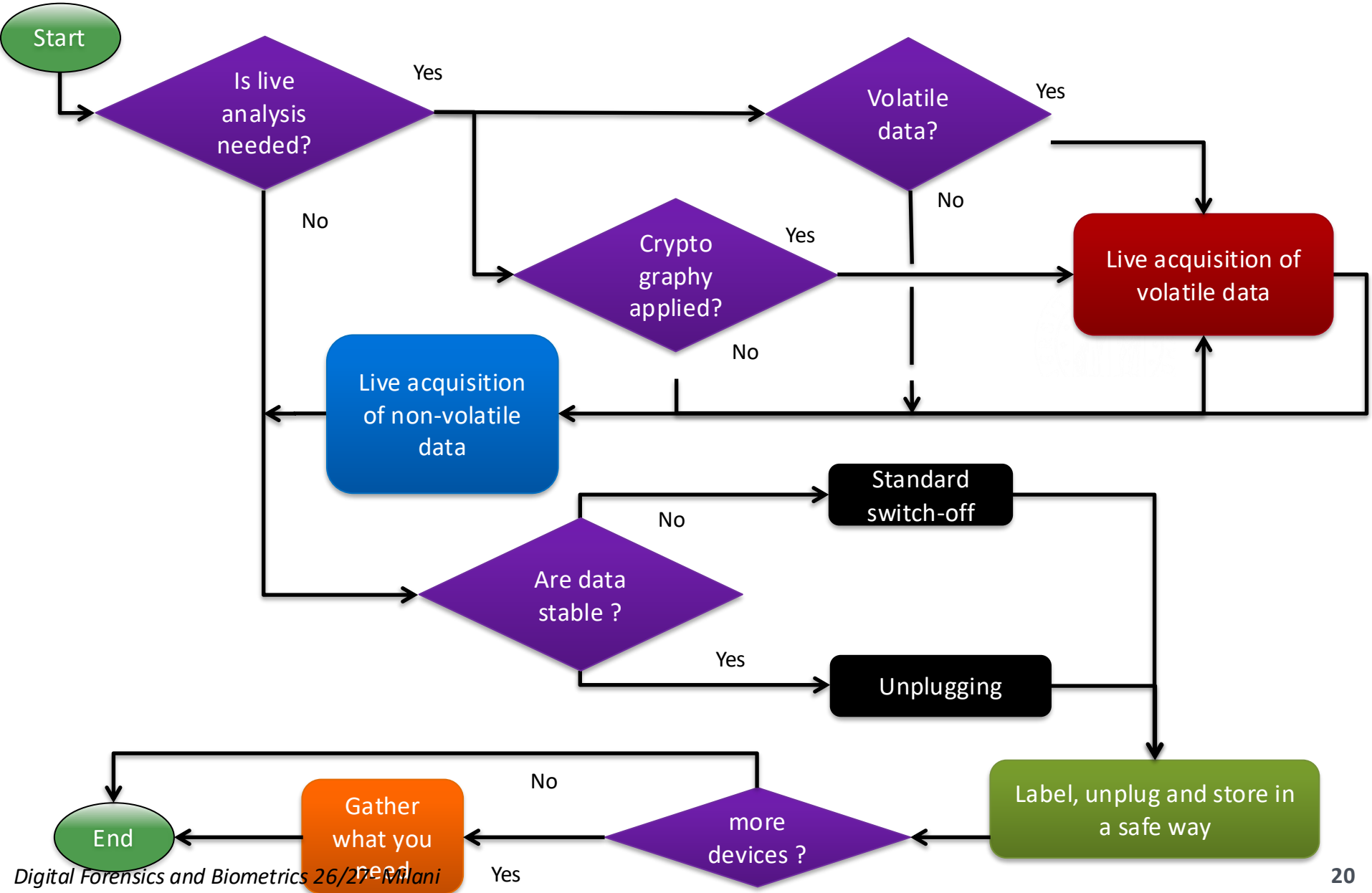


We can perform:

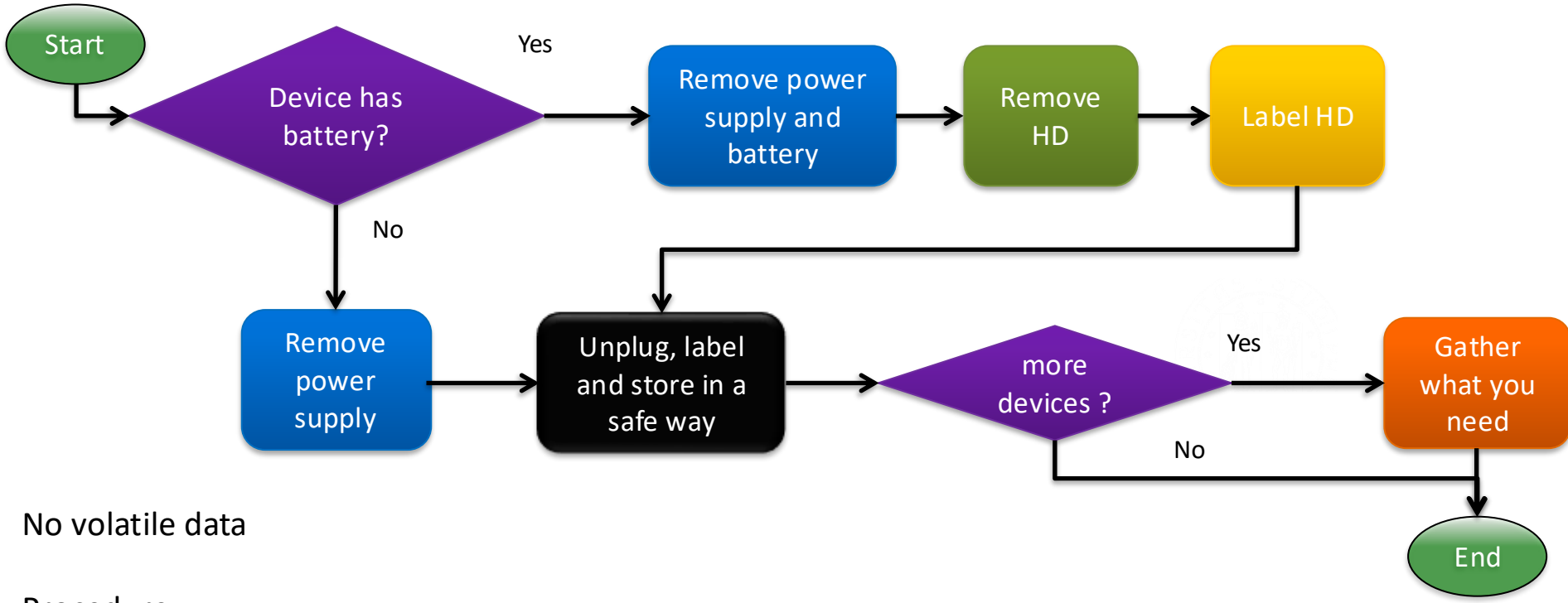
- **Live acquisition**
  -data are acquired on the spot
  -needed when device can not be seized or you fear losing information

- **Partial acquisition**
  Parts of the data are acquired
  - *System contains too many data (Google, DB servers, etc.)*
  - *System can not be switched off*
  - *Only part of the data are relevant*
  - *Only part of the data can be acquired (legal issues)*

COLLECTION: SWITCHED ON DEVICES



COLLECTION: SWITCHED-OFF DEVICES

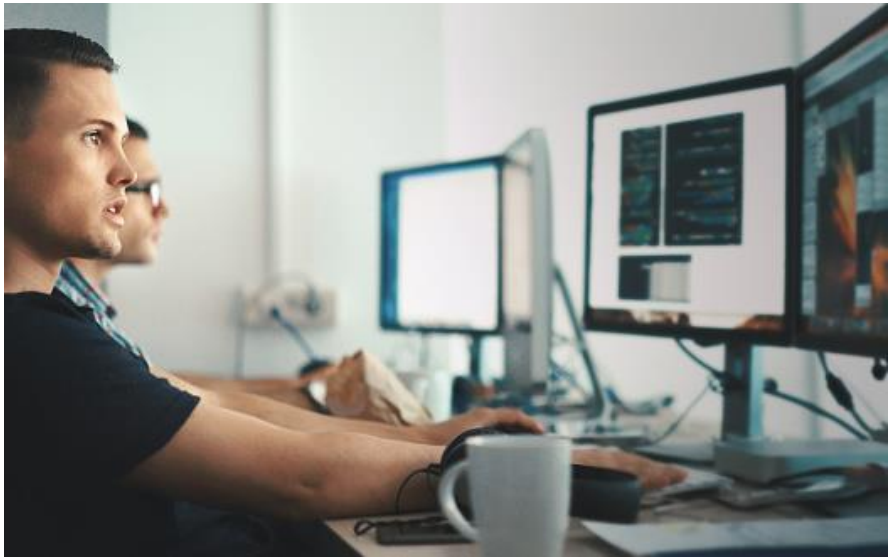


No volatile data

Procedure:

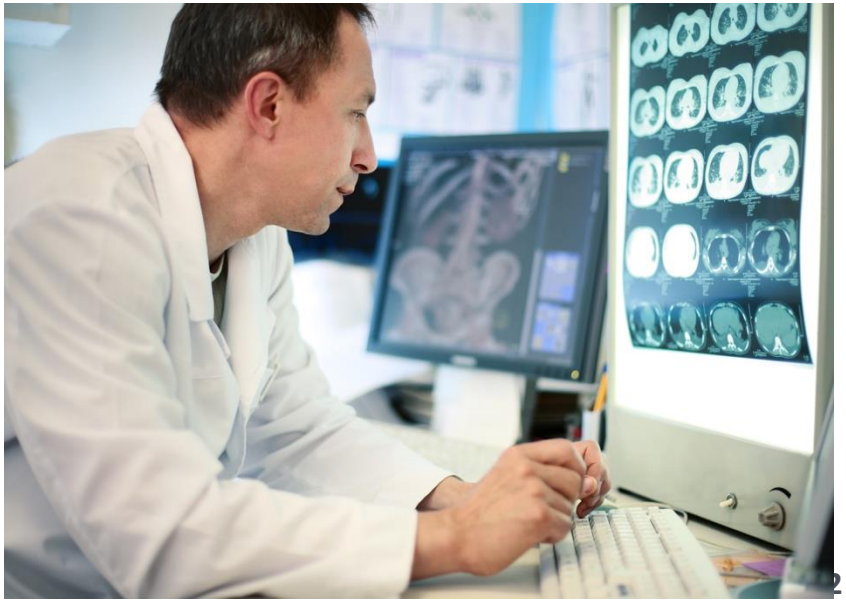
① Verify that all devices are really switched-off
② Remove memory storage from device (if not already)
③ Label memory device
④ Document details: type, vendor, s/n, part number, size
⑤ Acquire and compute hash value (for integrity verification)

CASE EXAMPLES









ACQUISITION

ACQUISITION

Create a forensic copy and document the method, the tools and the activity. What to acquire:

- Support
- Partition
- Files

Avoid altering the material (as much as possible)

- Do not change any bit
- If not possible, document some possible modifications and justify
  (e.g., the device is operating, there are damaged sectors, time is limited)



ACQUISITION: IMAGING

- Get data in a complete way minimizing alterations
- Printing and copying can be done but most of the meta-data are lost

Imaging is one of the most widely-used forensic srategy in acquisition

create a bit-stream copy of a disk or device in a non-invasive non-altering way; all the parts of the disk are copied (with meta-data)

Reliable forensic copy:
- Clone of a disk
- Bit-wise copy image
- Compressed bit-wise copy image



Cut&paste or Drag&drop are not forensic copies!

Misses erased files, slack space, free space; temporal data are lost;

NB. Disk cloning creates a functional one-to-one copy of a hard drive, while disk imaging creates an archive of a hard drive that can be used to make a one-to-one copy.

BASIC TOOLS FOR IMAGE ACQUISITION

dd (Linux)

```
dd if=/dev/sdc of = image.dd
```

/dev/sdc: input disk to image, image.dd: output "raw" disk data format.

dcfldd is an advanced version of **dd**; you can include more details, e.g., different hashing algorithms and split the input image to several output partitions.

```
dcfldd if=/dev/sdc hash = md5,sha256 hashwindow = 10G md5log = md5.txt \
        sha256log = sha256.txt split = 10G splitformat = aa of = image1.dd
```

Together with raw images we have formats:

Proprietary formats:

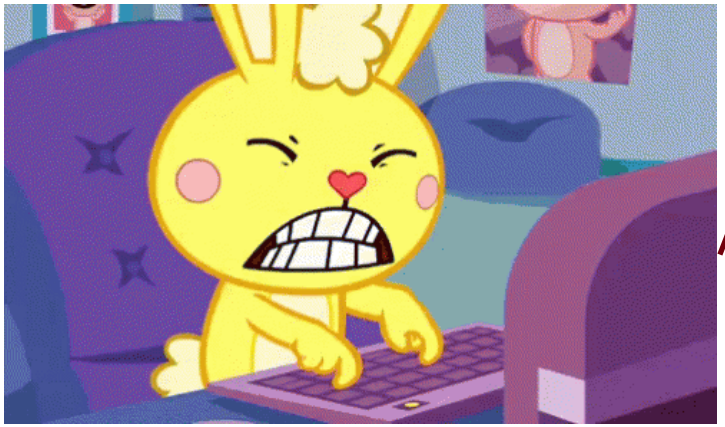
- EnCase (.E01,. E02, etc), ILook (compressed (IDIF), non-compressed (IRBF), and encrypted (IEIF)).
- encapsulated metadata
- you need the appropriate program.

Independent file formats (AFF, AFD and AFM)

- can be used across different tools
- collect disk and imaging process metadata.

ONLINE ACQUISITION EXAMPLE: DEFAMATING POSTS

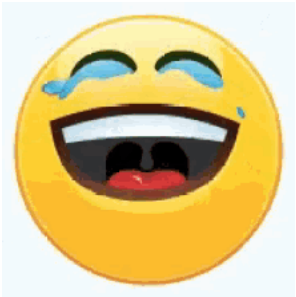
You find a defamating post on a facebook wall of a friend. Post is later removed. How to proceed?







You ask FB to provide a digital evidence for it



Facebook answers



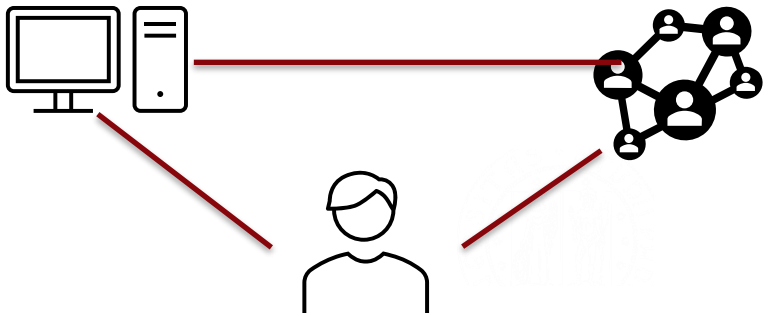
EXAMPLE OF LIVE ACQUISITION OF A POST

Acquire images from social media/web sites

Download with picture documentation (Es. screenshot or printout)

Problems:

- Malware
- Human errors
- Alterations



Computer – User – Network

OS live (open source)
Video registration
Visit some web sites: register network traffic
Use different softwares for hash computation

Profiling (SP not collaborating, shared PC)

Alternative: LegalEye

Problems: integrity of the environment and network

HOW TO ENSURE AUTHENTICITY

Given a file, how can I ensure it has not been altered?

Compute a sort of "signature" that changes whenever the file is altered.



Example:

Consider the sequence

12 34. 56. 78. 43. 45. 79. 81. sum=428 take the last digit. -> 8

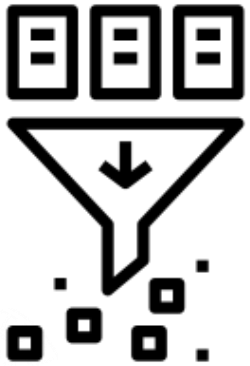
57 

The number changes

I need to modify another number

HASH FUNCTIONS

- Images are widely accepted in courts.
- Create more copies: 1 master and more copies to be given to all the legal actors involved
- Permits to give the resouce back to the owner



Integrity must be verified after the acquisition and generation of copies: create digest using **hash functions**

$$H: \quad \text{file} \rightarrow \{0,1\}^n$$

$$f \mapsto \mathbf{d}(f)$$

Digest: string of symbols/bits with predefined length generated by a hash function operated on the bits of a file/image.

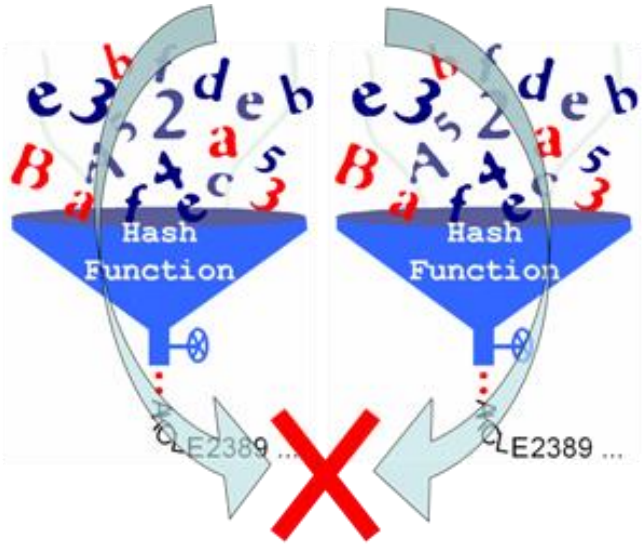
Hash function: non invertible function that maps variable length strings of symbols/bits into fixed length strings of bits.

- H is not mutual
- From digests it is not possible to reconstruct files
- It is very unlikely that two different files has the same digests (although probability is not null: **collisions**)
- It can be used to verify errors

HASH FUNCTIONS FOR CRYPTOGRAPHY

In cryptosystems, hash functions must have the following properties:

- **Resilience to pre-image**: given a digest **d**, creating a variable-length string f s.t. **d**(f)=**d** must be computationally-unfeasible
- **Resilience to second pre-image**: given a digest $\underline{\mathbf{d}}_1=\mathbf{d}(f_1)$ computed on a variable-length string f_1, it must be computationally-unfeasible to find f_2 s.t. $\underline{\mathbf{d}}_2=\mathbf{d}(f_2)=\underline{\mathbf{d}}_1$.
- **Resilience to collision:** searching for a couple of strings f_1 and f_2 such that $\mathbf{d}(f_2)=\mathbf{d}(f_1)$ is computationally-unfeasible.



HASH FUNCTION: MD5

Message Digest algorithm 5 , RFC1321 Ronald Rivest, 1991

variable

$$\begin{array}{lccc} \mathrm{MD5}: & \{0,1\}^{l} & \rightarrow & \{0,1\}^{128} \\ & \mathbf{s} & \mapsto & \mathbf{d}(\mathbf{s}) \end{array}$$

Maps variable-length strings into strings with 128 bits

MD5 checksum or MD5 hash

- Fast
- Highly-improbable to find 2 different strings with the same MD5 hash
- Many resources online allows to decipher common words (www.md5online.org)
- Widely diffused

Example: ➡ = decrypt!

"Digital Forensics" MD5: **093005a1f5950fba6c6a8b628c8e3a22** ➡ **"Digital Forensics"**
"This is ciphered text for Digital Forensics course!" MD5: **8bdf55f7b5ec03f5671440c8db9d876c** ➡ **Not found**

Today there are many tools that permits generating couple of strings colliding!

```
C:\TEMP> md5sum hello.exe
cdc47d670159eef60916ca03a9d4a007
C:\TEMP> .\hello.exe
Hello, world!

(press enter to quit)
C:\TEMP>
```

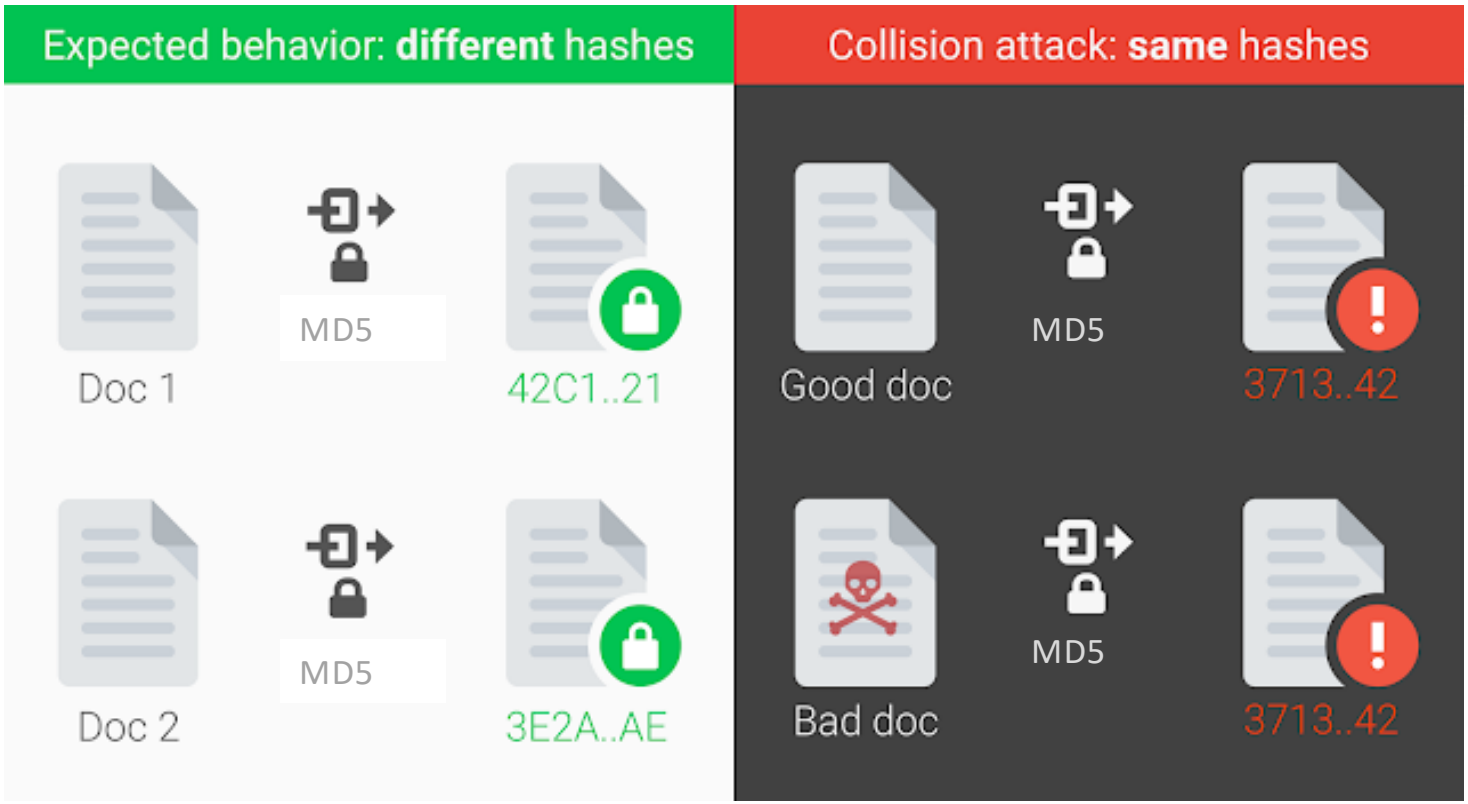
```
C:\TEMP> md5sum erase.exe
cdc47d670159eef60916ca03a9d4a007
C:\TEMP> .\erase.exe
This program is evil!!!
Erasing hard
drive...1Gb...2Gb... just
kidding!
Nothing was erased.

(press enter to quit)
```

COLLISION ATTACKS

Let us put on a black hat !





HASH FUNCTION: SHA

Secure Hash Algorithm

National Security Agency (NSA), 1993 - NIST USA federal standard FIPSPUB180-4.

5 different cryptographic functions

- SHA-1
- SHA-224
- SHA-256
- SHA-384
- SHA-512

} SHA-2

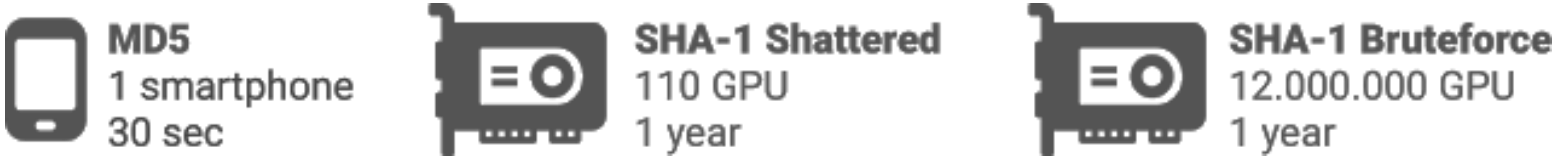
- ❑ SHA-1: digests of 160 bits (most widely used)
- ❑ SHA-2: digests of different lengths SHA-<n> ➡ digest of n bits!

Results	
Original text	*(binary only)*
Original bytes	ffd8ffe2021c4943435f50524f46494c450001010000020c6c... (length=94841)
Adler32	7fb3b6a1
CRC32	9208beae
Haval	cd28f16055cbad8560f06ebb97edf0d4
MD2	98d7dad1c73a0189240683ffa3a8593f
MD4	c2e0c4d449d989ce88c33d056bc8c6ca
MD5	08ee31606c4cedc736c716da0b10329a
RipeMD128	bac154b92a027925ff93fc3b3ba51d71
RipeMD160	b363eed5bd2f6b079d7177c4ac36db05cb39f1ed
SHA-1	a42c8ba3acf44a35dcb206ee5be88ecf8c946339
SHA-256	d36f2f1c227cab5ee7d03a1ea33faf5f1c0b480315429020bd60012baa1accaa
SHA-384	272964d98b9bb39aea248d0a6167300e16baae6c49403a8a8fd2797751e06587140c3ba7c5e00eac0ac1a024816e08fc
SHA-512	2e89f38aa25cb1f1200655e6d08771d12c415556bb63f9d58b12b2aa566a1ccae790cd44ac56a5a9c5aa80fde686aec237ba0ef2db00bdb4636050d5562cf9d3

NOTHING IS COMPLETELY SECURE

Google Security Blog, Announcing the first SHA-1 collision, 2017, link





PRESERVATION OR CONSERVATION

CONSERVATION

Protect data from alterations (natural, on-purpose, damages, etc.)

Crucial whenever evidences are **accessed, analyzed** and **transferred.**

Methodology is provided to verify that **no alterations** occurred

Privacy must be protected as well

Special packaging could be needed
- Magnetic supports, anti-static cases



Cautions:
- Data must adequately labelled
- Verify that batteries are adequately charged (and re-charged), if present
- Fix mobile parts
- Minimize risks concerning the type of support
- Minimize transportation risks
- Preserve eventual additional traces
  - Biological traces, fingerprints
  - Use gloves
- Secured in a safe place, protected by a security mechanism (keys), accessed only by authorized personnel,

CHAIN OF CUSTODY

History of the service/support starting from the intervention moment: forensic version of **log files**

Documenting material in **handling, processing** and **preserving** DE

Paper/digital documentation

Crucial in the legal process.

Example: *In the O.J. Simpson trial, for example, Simpson's defense showed that crime scene blood samples had been in the possession of multiple investigating officers for various lengths of time without being properly recorded on the Chain of Custody Form. This omission enabled the defense to create doubt in the minds of the jurors that blood evidence linking Simpson to the crime could have been planted or contaminated to frame him.*

CHARACTERISTICS OF CHAIN OF CUSTODY

- Record:
  1. Who collected DE
  2. Where it was stored
  3. Who accessed it and why
  4. When and how it was transferred

- Must ensure that the DE is untampered and admissible in court

How?

A. Documentation of collection process
B. Labelling evidences and devices (serial ID), together with hash codes and info
   -date, time, location of collection;, who collected the evidence and his/her role in the investigation
C. Secured in a safe place, protected by a security mechanism (keys), accessed only by authorized personnel
D. Every access must be logged with 5Ws (who, What, Where, When and Why)
E. Log transfer and handling of evidence

.

CASE: KILLING OF CAYLEEN ANTHONY 2008

Casey Anthony trial (2011)

-prosecuted for the killing of her daughter

-browser forensics: she search terms used in Google for 'how to make chloroform' and 'neck breaking'

-listed 84 visits to a website which referenced making 'chloroform'.

But

-Firefox history data (which this evidence was recovered from) was located in unallocated space and could not be attributed to a specific user (multiple user accessed the PC)

-4 separate forensic examination tools were used; different results

-not properly reported and documented

Result

–not guilty of first-degree murder, aggravated child abuse, and aggravated manslaughter of a child, but guilty of four misdemeanor counts of providing false information to a law enforcement officer.



https://www.digital-detective.net/digital-evidence-discrepancies-casey-anthony-trial/

https://belkasoft.com/basic-but-significant-legal-issues-casey-anthony-case

CASE: SILKROAD 2013

SilkRoad prosecution (2013)

-hidden service on the Tor network launched in 2011
-based on Tor and Bitcoin transactions
-difficult to track and anonymity-based
- >200M$ in illegal drugs and other illicit goods

But

-Tor browser history, configuration files, and network connections to uncover user activity.
-Investigators could access transaction records by reviewing wallet data,
-evidences could be correlated such as memory dumps, file systems, and network traces.
-all evidences were collected and presented in correct way; strict adherence to forensic protocols

Result

–In Oct. 2013, Ross Ulbright was arrested while his laptop remained open, allowing investigators to seize unencrypted evidence.

https://belkasoft.com/silk-road-investigation-lessons-learned



CASE: GARLASCO 2007

Casey SilkRoad prosecution (2013)

-A. Stasi was accused of murdering his girlfriend C. Poggi.
-his alibi was verified looking for his phone call and work of the final thesis
-laptop was analyzed to verify his activities during the day

But

-compiuter was not analyzed properly: 73,8 visible files were erased during the investigation
-forensic experts managed to recover lost information and verify he has been working anyway on the thesis

Result

–A. Stasi was judged not guilty in Primo Grado (first trial) - later convicted by Cassazione 2015-

https://canestrinilex.com/risorse/la-verita-processuale-sul-delitto-di-garlasco-cass-2579916



SOME TIPS

- Use proper forensic tools to document and analyze data
- Maintain access logs
- Timestamp operations
- Verify and hash data
- All the team must be trained and aligned to specific protocols

ADDITIONAL NOTES ON CHAIN OF CUSTODY

- Document and justify every possible alteration (with the name of the person which is responsible for that)
- Record dates if items are released to anyone
- Restrict access to the evidence
- Place original hard drive to a locker
- Perform all forensics on a mirror copy